



Kerberos برای تست نفوذ و رد تیم



TryHackBox

توسط کاوه



عنوان :	کربروس برای تست نفوذ و رد تیم
نویسنده :	کاوه
ارتباط با نویسنده :	https://www.x.com/kavehxnet
کانال شخصی بنده در تلگرام :	https://t.me/KavehAPT
کانال آموزش ما در تلگرام :	https://t.me/TryHackBox
تاریخ انتشار :	اردیبهشت 1404
نسخه :	اول

به دانش توان ساختن شهر و دیار

به جهل اندرون، خویشتن خوار شود

این کتابچه صرفاً جنبه آموزشی دارد و در راستای ارتقای فرهنگ و دانش امنیت سایبری تمامی علاقه مندان این حوزه به صورت کاملاً رایگان تهیه و انتشار یافته است؛ لذا هرگونه تکثیر جهت استفاده تجاری ممنوع است؛ هرگونه توزیع و تکثیر از این اثر با ذکر نام نویسنده و منبع آن بلامانع خواهد بود. این جزوه ممکن است دارای اشکالات نوشتاری و فنی جزئی باشد که از نظر تهیه کننده مغفول مانده باشد؛ لذا از شما خواننده فهیم در خواست میشود از طریق تویتر اشکالات، انتقادات و پیشنهادات خود را در جهت تکمیل این کتابچه عملی اقدام فرمایید. خواننده گرامی برای تهیه این اثر زمان و انرژی زیادی صرف شده است و در راستای ارتقاء دانش علمی و فرهنگ امنیت سایبری به صورت رایگان انتشار یافته، هزینه استفاده از این اثر خواندن فاتحه برای خواهرم خواهد بود. در صورتی که این اثر برای شما مفید بود به منظور حمایت از نویسنده جهت ارائه نسخه های جدیدتر می توانید به هر میزان مبلغ دلخواه حمایت کنید:

<https://daramet.com/TryHackBox>

گیت هاب ما :

<https://github.com/TryHackBox>



سخن پایانی نویسنده:

از اینکه این کتاب را انتخاب کردید و گام به گام در این سفر آموزشی همراه من بودید، صمیمانه سپاسگزارم. امیدوارم این محتوا برای شما که به دنیای تست نفوذ شبکه و عملیات تیم قرمز علاقه‌مند هستید، مفید و عملی باشد. این مجموعه، حاصل ساعت‌ها پژوهش و تجربیات عملی من در حوزه رد تیم و کار با پروتکل Kerberos است. هدفم این بود که مفاهیم پیچیده احراز هویت و نقاط ضعف این پروتکل را به زبانی ساده و کاربردی ارائه دهم تا شما بتوانید از این دانش در سناریوهای واقعی بهره ببرید.

اما این پایان مسیر نیست! اگر در طول مطالعه با ابهاماتی مواجه شدید، اشکالاتی مشاهده کردید یا پیشنهادی برای بهبود دارید، با کمال میل پذیرای نظرات ارزشمند شما هستم. بازخوردهای شما نه تنها به ارتقای کیفیت این محتوا کمک می‌کند، بلکه زمینه‌ساز تولید منابع آموزشی کامل‌تر در آینده خواهد بود. این راهنما یکی از دیگر گام‌های من در مسیر تولید محتوای تخصصی فارسی در حوزه تست نفوذ و رد تیم تحلیل پروتکل‌های امنیتی مانند Kerberos است. برنامه‌های گسترده‌ای برای آینده دارم

با آرزوی موفقیت روزافزون برای شما در مسیر حرفه‌ای شدن در حوزه رد تیم و تست نفوذ .

با احترام، کاوه



کربروس برای متخصص تست نفوذ – بخش اول: تئوری

فهرست مطالب

- مقدمه
- تاریخچه مختصر و مرور کلی
- الزامات پروتکل Kerberos
- کاربرد در تیم قرمز (Red Team)
- فهرست اصطلاحات
- احراز هویت با استفاده از Kerberos
- 5.1. تشبیه کاربردی (توضیح ساده با مثال روزمره)
- 5.2. مرور کلی فرآیند
- استفاده از Kerberos در تیم قرمز (Red Team) چگونه است؟
- تجزیه و تحلیل فرآیند احراز هویت در Kerberos بر اساس RFC
- 6.1. الگوریتم تشکیل کلید
- 6.2. KRB_AS_REQ
- 6.3. KRB_AS_REP
- 6.4. KRB_TGS_REQ
- 6.5. KRB_TGS_REP
- 6.6. KRB_AP_REQ
- 6.7. KRB_AP_REP
- کربروس در اکتیو دایرکتوری (Active Directory)
- کاربرد در تیم قرمز
- 7.1. احراز هویت کاربر دامننه در ایستگاه کاری (در محیط AD)
- 7.2. KRB_AS_REQ با احراز هویت مقدماتی (Pre-Authentication)
- این فرایند در تیم قرمز چگونه کاربرد دارد؟
- 7.3. KRB_AS_REP (in AD)
- 7.4. KRB_TGS_REQ (in AD)
- 7.5. KRB_TGS_REP (in AD)
- 7.6. فرآیند لاگین (LOGON)
- جمع بندی



مقدمه

به نظر من برای متخصصین تست نفوذ در زیرساخت‌های مبتنی بر Active Directory ، درک ساختار کلی پروتکل Kerberos از اهمیت ویژه‌ای برخوردار است. در اینجا به چند دلیل کلیدی اشاره می‌کنم:

1. آشنایی با ساختار پروتکل Kerberos برای درک بسیاری از حملات کلاسیک ضروری است.
2. حملات جدید به صورت دوره‌ای ظهور می‌کنند، اما قبل از بهره‌برداری از آنها، باید پیامدهای احتمالی را درک کرد. بدون دانش Kerberos ، این کار اغلب دشوار یا حتی غیرممکن است.
3. باور شخصی من این است که اگر کسی خود را متخصص می‌نامد، باید دانشی عمیق‌تر از صرفاً شناخت نام ابزارها یا دکمه‌هایی که باید کلیک شوند، داشته باشد.

درباره Kerberos و حملات مربوط به آن مقالات زیادی نوشته شده است. بسیاری از این مقالات یا برای ریاضیدانان، یا برای مهندسان شبکه، یا برای متخصصین تست نفوذ نوشته شده‌اند. مطالب اغلب به صورت پراکنده و یک‌بعدی ارائه می‌شوند و زمان زیادی باید صرف انتخاب مطالب مفید و یکپارچه‌سازی آنها در یادداشت‌های شخصی کرد.

در اینجا ، قصد دارم هم به بررسی تئوری ساختار پروتکل Kerberos و هم به حملات عملی قابل اجرا با استفاده از آن در Active Directory بپردازم. همچنین توصیه‌هایی برای مقابله با این حملات ارائه خواهد شد.

در بخش اول، به بررسی ساختار کلی Kerberos و پیاده‌سازی آن در Active Directory خواهیم پرداخت.

تذکر مهم: این مطالب را نباید به عنوان حقیقت مطلق در نظر گرفت. تنها احمق‌ها هستند که هیچ شکی به خود راه نمی‌دهند.

تاریخچه مختصر و مرور کلی

پروتکل Kerberos در دانشگاه MIT به عنوان بخشی از پروژه تحقیقاتی آتنا (Athena) توسعه یافت که هدف آن ایجاد یک محیط آموزشی توزیع شده بود. تا سال 1988، این پروژه به اهداف خود دست یافت و مشخصات پروتکل Kerberos نسخه 4 به عنوان پایه‌ای برای سیستم تک ورود (SSO) در این محیط منتشر شد. نسخه‌های 1 تا 3 تنها نمونه‌های اولیه بودند و خارج از MIT استفاده نشدند.

در سال 1989، Kerberos نسخه 4 به طور رسمی منتشر شد. اما این پروتکل نیاز به توسعه بیشتری داشت. برخی از نقاط ضعف نسخه 4 عبارت بودند از:



1. استفاده از الگوریتم‌های رمزنگاری ضعیف
2. آسیب‌پذیری‌های معماری که امکان حملات آفلاین پروتفوری علیه رمزهای عبور کاربران را فراهم می‌کرد
3. عدم امکان delegation اعتبارنامه‌ها یا استفاده از فاکتورهای اضافی احراز هویت

برای رفع این مشکلات، نسخه جدید Kerberos نسخه 5 در سال 1993 منتشر شد.

در سال 1999، مایکروسافت از پشتیبانی Kerberos نسخه 5 در سیستم عامل آینده خود یعنی ویندوز 2000 خبر داد که بعدها به عنوان بخشی از Active Directory پیاده‌سازی شد. قبل از آن، در محیط‌های کاری ویندوز از پروتکل NT LAN Manager (NTLM) استفاده می‌شد که نسخه دوم آن (NTLM v2) هنوز هم در سیستم‌های مدرن برای احراز هویت محلی به کار می‌رود.

امروزه می‌توان Kerberos نسخه 5 را پروتکلی نسبتاً قدیمی دانست، اما همچنان در بسیاری از سیستم‌ها - نه فقط Active Directory استفاده می‌شود. برخی از این سیستم‌ها شامل:

- سرویس‌های وب آمازون (AWS)
- سیستم عامل macOS اپل
- گوگل Cloud
- مایکروسافت Azure
- اوراکل سولاریس
- ردهت لینوکس

در ادامه این کتابچه، منظور از Kerberos همان نسخه 5 خواهد بود و برای سهولت خوانش، آن را به سادگی Kerberos می‌نامیم.

الزامات پروتکل Kerberos

درک نحوه عملکرد پروتکل Kerberos در ابتدا کار ساده‌ای نیست. دائماً باید مطالب مطالعه شده را مرور کرد و جزئیات زیادی را به خاطر سپرد. اغلب این سوال پیش می‌آید: چرا همه چیز اینقدر پیچیده طراحی شده است؟

برای پاسخ صحیح به این سوال و درک آن، نیاز به دانشی در مورد ساختار پروتکل‌های رمزنگاری و علوم مرتبط داریم. به نظر من نیازی به بررسی بیش از حد عمیق نیست. اما برای درک دلایل پیچیدگی‌های Kerberos، برخی از الزاماتی که این پروتکل باید رعایت می‌کرد را ذکر می‌کنم:



1. فرض بر این است که تبادل پیام‌ها بین دستگاه‌های مورد اعتماد، اما در یک محیط باز و غیرقابل اعتماد انجام می‌شود. ترافیک شبکه ممکن است توسط مهاجمان شنود شود و پیام‌ها ممکن است جعل یا تغییر مسیر داده شوند. بنابراین، اسرار شرکت‌کنندگان در پروتکل تحت هیچ شرایطی نباید به صورت واضح در شبکه منتقل شوند.

○ نکته جالب : Kerberos قبل از ظهور SSL توسعه یافته است.

2. اطلاعات کاربران و اسرار آنها باید در مکانی اختصاصی ذخیره شود. این محدودیت به دلایل زیر ایجاد شده است:

○ باید تعداد اشیاء حیاتی که نیاز به محافظت دارند به حداقل برسد.

○ اضافه کردن موارد جدید، حذف موارد قدیمی یا تغییر اسرار فعلی برای سرویس‌دهنده یا سرویس‌گیرنده نباید نیاز به اطلاع‌رسانی به سایر شرکت‌کنندگان در پروتکل داشته باشد.

کاربرد در تیم قرمز (Red Team)

درک این الزامات برای تیم‌های قرمز حیاتی است زیرا:

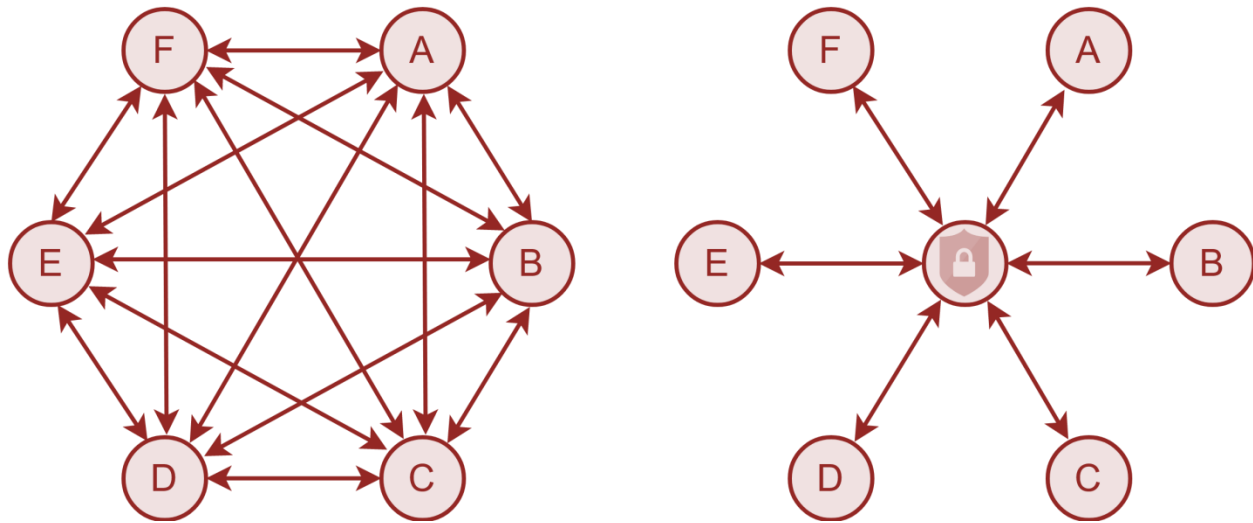
1. شناسایی نقاط ضعف در پیاده‌سازی Kerberos را ممکن می‌سازد
2. به طراحی حملات هدفمند کمک می‌کند
3. امکان سوءاستفاده از محدودیت‌های پروتکل را فراهم می‌آورد

تکنیک‌های کلیدی:

- سوءاستفاده از انتقال ناامن اسرار در شبکه
- بهره‌برداری از مکان‌های ذخیره‌سازی متمرکز
- استفاده از تغییرات غیرمجاز در اسرار

ابزارهای مفید:

- Wireshark برای تحلیل ترافیک Kerberos
- Mimikatz برای استخراج اسرار (secrets)
- Impacket برای تست محدودیت‌های پروتکل



شبکه‌های بدون مرکز اعتماد متمرکز و با مرکز اعتماد متمرکز

1. شبکه‌های بدون مرکز اعتماد متمرکز (Decentralized Networks)

• ویژگی‌ها:

- هر نود/سیستم به تنهایی مسئول احراز هویت و مدیریت اعتبارهاست
- نیاز به توافق جمعی (Consensus) برای تایید تراکنش‌ها
- معمولاً از رمزنگاری نامتقارن استفاده می‌شود

• مثال‌ها:

- شبکه‌های هم‌تا به هم‌تا (P2P)
- بلاکچین و ارزهای دیجیتال
- سیستم‌های فایل شیرینگ غیرمتمرکز

• مزایا:

- عدم وجود نقطه شکست واحد (Single Point of Failure)
- مقاومت در برابر سانسور
- ناشناس بودن نسبی

• معایب:

- پیچیدگی مدیریت کلیدها
- کارایی پایین‌تر در مقیاس بزرگ
- مشکل در بازگردانی دسترسی از دست رفته



2. شبکه‌های با مرکز اعتماد متمرکز (Centralized Trust Authority Networks)

• ویژگی‌ها:

- وجود یک سرور مرکزی معتبر (مانند KDC در Kerberos)
- مدیریت متمرکز هویت و اعتبارسنجی
- معمولاً از ترکیب رمزنگاری متقارن و نامتقارن استفاده می‌شود

• مثال‌ها:

- پروتکل Kerberos
- Active Directory
- سیستم‌های PKI (زیرساخت کلید عمومی)

• مزایا:

- مدیریت متمرکز و ساده‌تر
- کارایی بالا در محیط‌های سازمانی
- امکان پیاده‌سازی سیاست‌های امنیتی یکپارچه

• معایب:

- وجود نقطه شکست مرکزی
- نیاز به حفاظت شدید از سرور مرکزی
- مشکلات مقیاس‌پذیری در برخی موارد

3. پشتیبانی از فناوری ورود یک‌باره (Single Sign-On - SSO) :

این نیاز به این دلیل وجود دارد که کاربران نباید مجبور باشند برای هر دسترسی به منابع مختلف، مجدداً رمز عبور خود را وارد کنند.

- **مزیت اصلی:** بهبود تجربه کاربری و کاهش بار شناختی برای کاربران
- **چالش امنیتی:** در صورت به خطر افتادن اعتبار کاربر، مهاجم می‌تواند به چندین سرویس دسترسی پیدا کند.

4. احراز هویت دوطرفه موفق (Mutual Authentication) :

پایان موفقیت‌آمیز پروتکل باید به معنای تأیید هویت هر دو طرف (هم سرویس‌دهنده و هم سرویس‌گیرنده) باشد.



- چرا مهم است؟ جلوگیری از حملات مرد میانی (MITM) که در آن مهاجم خود را به جای سرویس واقعی جا می‌زند.
- مثال در Kerberos: سرویس گیرنده نیز باید بتواند صحت سرویس دهنده را تأیید کند (نه فقط بالعکس).

5. ایجاد کلید جلسه امن (Session Key) بین کلاینت و سرویس:

- این کلید برای رمزنگاری ارتباطات طی جلسه استفاده می‌شود.
- محدودیت امنیتی: اگر مهاجم این کلید را بدزدد، می‌تواند پیام‌های گذشته را رمزگشایی کند، اما نمی‌تواند جلسه جدیدی با همان کلید ایجاد کند.
- دلیل: کلیدهای جلسه در Kerberos معمولاً محدود به زمان هستند (بر اساس TGT و Ticket عمر محدود دارند).

کاربرد در رد تیم

این ویژگی‌های Kerberos هم نقطه قوت و هم نقطه ضعف هستند:

1. سوءاستفاده از SSO:

- اگر مهاجم اعتبار کاربری را به دست آورد (مثلاً با **Pass-the-Hash** یا **Kerberoasting**) می‌تواند به چندین سرویس دسترسی پیدا کند.
- ابزارها **Mimikatz**: (برای استخراج TGT ها) **Rubeus** (برای سوءاستفاده از Ticket ها).

2. حملات علیه احراز هویت دوطرفه:

- برخی پیاده‌سازی‌های ضعیف ممکن است احراز هویت سرویس دهنده را نادیده بگیرند (مثلاً در سرویس‌های غیرفعال شده).
- حمله **Silver Ticket** از این ضعف استفاده می‌کند.

3. سوءاستفاده از کلیدهای جلسه:

- با **تکثیر بلیط (Ticket Forgery)**، مهاجم می‌تواند ارتباطات گذشته را رمزگشایی کند (مثلاً برای استخراج داده‌های حساس).
- اما ایجاد جلسه جدید نیاز به **TGT تازه** دارد (مگر اینکه حمله **Golden Ticket** انجام شود).

فهرست اصطلاحات

پیش از پرداختن به بخش فنی، اجازه دهید اصطلاحات را تعریف کنیم تا از سردرگمی جلوگیری شود.



Kerberos در درجه اول یک پروتکل احراز هویت است، اما امکان انتقال اطلاعات لازم برای مجوزدهی را نیز فراهم می‌کند.

مهم است که اشتباه نشود:

- **احراز هویت (Authentication):** فرآیند تأیید اصالت. یعنی بررسی اینکه کاربری که سعی در دسترسی به سیستم دارد، واقعاً همان کسی است که ادعا می‌کند.
- **مجوزدهی (Authorization):** فرآیند بررسی حقوق دسترسی. مجوزدهی فقط می‌تواند برای کاربری که احراز هویت شده است اعمال شود، زیرا قبل از بررسی حقوق دسترسی، باید هویت شیئی که قرار است این حقوق به آن اعطا شود، مشخص شود.

سرور (Server): شیء شبکه‌ای که عملکرد یک یا چند سرویس را تضمین می‌کند. مثال‌ها: سرور فایل، سرور ایمیل.

کلاینت (Client): شیئی که برای دسترسی به منابع به سرویس مراجعه می‌کند. مثال‌ها: حساب کاربری یا ایستگاه کاری کاربر.

حوزه عملکرد (Realm): مجموعه‌ای از کلاینت‌ها، سرورها و سرویس‌هایی که در پروتکل Kerberos مشارکت دارند.

اصیل (Principal): این یک رشته است که به طور کامل یک شرکت‌کننده در پروتکل Kerberos را شناسایی می‌کند.

Principal می‌تواند نام یک سرویس (Service Principal Name) یا نام یک کلاینت (User Principal Name) باشد. فرمت **Principal** ها برای کلاینت‌ها و سرویس‌ها متفاوت است.

Principal کلاینت به شکل زیر است:

```
principal-name[/instance-name]@REALM
```

مثال: اگر نام کاربری Ivan و حوزه عملکرد DOMAIN.LOCAL باشد، **Principal** کامل به این صورت خواهد بود:

Ivan@DOMAIN.LOCAL.



قسمت instance-name اختیاری است و به هر کاربر اجازه می‌دهد بیش از یک **Principal** داشته باشد. مثلاً اگر Ivan مدیر حوزه DOMAIN.LOCAL باشد، نام Principal به این صورت خواهد بود : Ivan/admin@DOMAIN.LOCAL ، و این Principal حقوق دیگری خواهد داشت (و مدارک تأیید کننده دیگری).

سرویس **Principal** به شکل زیر است:

service-name/host[:port]@REALM

که در آن:

- service-name : رشته خاص برنامه است که سرویس را در این میزبان شناسایی می‌کند.
- Host : نام دامنه میزبانی که سرویس روی آن اجرا می‌شود.
- Port : پورتهی که سرویس روی آن اجرا می‌شود.

مثال: برای سرویس ftp که روی میزبان با نام ftpserver.example.com در حوزه @EXAMPLE.COM اجرا می‌شود، نام **Principal** سرویس به این صورت خواهد بود:

ftp/ftpserver.example.com@EXAMPLE.COM.

چرا این همه توجه به این نام‌ها می‌شود؟ در ادامه روشن‌تر خواهد شد، اما همین حالا می‌توان اشاره کرد که در Kerberos برای شناسایی سرور، دقیقاً به **Principal** (نام) نیاز است، در حالی که در NTLM می‌توان از آدرس IP استفاده کرد.

نکته : امکان استفاده از آدرس‌های IP در کلاینت‌های جدید ویندوز اضافه شده است.

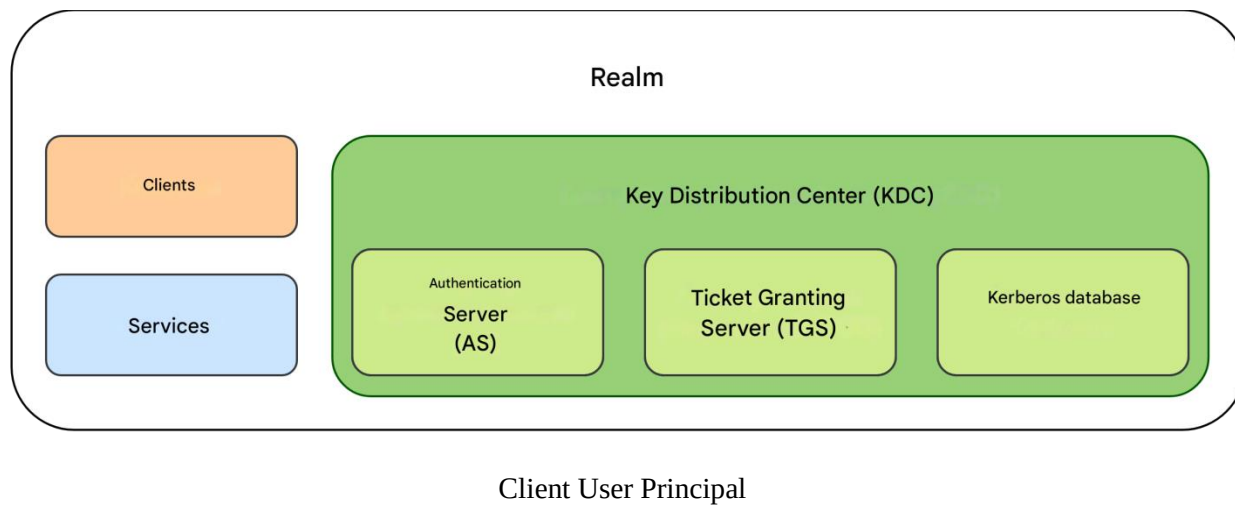
مثالی بزنیم: یک ایستگاه کاری (با نام station.domain.local ، DNS: station.domain.local ، آدرس IP: 192.168.10.12) با یک پوشه شبکه عمومی به نام scan وجود دارد. هنگام باز کردن File Explorer و رفتن به مسیر UNC \\station.domain.local\scan ، از Kerberos استفاده می‌شود، اما با مشخص کردن مسیر UNC \\192.168.10.12\scan ، از NTLM استفاده می‌شود، زیرا **Principal** وجود ندارد. به ویژه، به همین دلیل است که مدیران سیستم دوست ندارند NTLM را غیرفعال کنند، زیرا تجهیزات شبکه قدیمی (چاپگرها، روترها و غیره) ممکن است با آدرس‌های IP ثابت پیکربندی شده باشند یا اصلاً از Kerberos پشتیبانی نکنند.



مرکز توزیع کلید (Key Distribution Center، به اختصار KDC): مرکز احراز هویت مورد اعتماد برای همه شرکت کنندگان در پروتکل Kerberos در یک حوزه عملکرد مشخص است.

KDC شامل اجزای زیر است:

- پایگاه داده Kerberos: برای ذخیره اطلاعات همه **Principal** ها و اسرار آنها.
- سرور احراز هویت (AS، Authentication Server): درخواست های احراز هویت کلاینت ها به حوزه عملکرد پروتکل Kerberos را پردازش می کند.
- سرور اعطای بلیط (TGS، Ticket Granting Server): درخواست های احراز هویت به یک سرویس خاص را که در حوزه عملکرد مشخص شده فعالیت می کند، پردازش می کند.



احراز هویت با استفاده از پروتکل Kerberos



تصویرسازی ترتیب ارائه مطالب

فرآیند احراز هویت Kerberos به صورت زیر کار می کند:

1. درخواست اولیه (AS-REQ)
 - کلاینت درخواست Ticket Granting Ticket (TGT) را به سرور احراز هویت (AS) ارسال می کند
2. پاسخ احراز هویت (AS-REP)
 - AS یک TGT رمزنگاری شده برای کلاینت ارسال می کند
3. درخواست بلیط سرویس (TGS-REQ)



- کلاینت از TGT برای دریافت بلیط سرویس از TGS استفاده می کند
- 4. پاسخ بلیط سرویس (TGS-REP)
- TGS بلیط سرویس رمزنگاری شده را برای کلاینت ارسال می کند
- 5. درخواست برنامه (AP-REQ)
- کلاینت بلیط سرویس را به سرور مورد نظر ارائه می دهد
- 6. پاسخ برنامه - (AP-REP) اختیاری
- سرور ممکن است پاسخ تأیید ارسال کند

درک پروتکل Kerberos : بیایید از کلیات به جزئیات برویم .

یک مثال روزمره

بیایید یک موقعیت کمی ساختگی اما مفید برای تشبیهات بعدی را در نظر بگیریم. فرض کنید یک پارک تفریحی داریم. فرض کنیم فهرست بازدیدکنندگان مجاز پارک در یک پایگاه داده خاص ذخیره شده است. کسانی که در این پایگاه داده نیستند اجازه ورود ندارند. نحوه سازماندهی بازدید از پارک به این صورت است:

1. بازدیدکننده به ورودی می آید و کارت عبور خود را به نگهبان نشان می دهد.
2. نگهبان وجود بازدیدکننده را در پایگاه داده بررسی می کند.
3. نگهبان یک بلیط یک روزه برای بازدید از پارک به بازدیدکننده می دهد.
4. بازدیدکننده یک تفریحگاه مورد نظر خود را انتخاب کرده و به باجه می رود تا بلیط بگیرد.
5. در باجه بلیط یک روزه بازدیدکننده بررسی شده و بلیط مربوط به تفریحگاه صادر می شود.
6. بازدیدکننده به تفریحگاه مورد نظر خود می رود و بلیط دریافتی از باجه را به نگهبان تفریحگاه نشان می دهد.
7. نگهبان بلیط را بررسی کرده و بازدیدکننده را اجازه ورود می دهد.
8. بازدیدکننده در صورت تمایل می تواند نشان شناسایی نگهبان را بررسی کند تا مطمئن شود که او واقعاً یک کارمند پارک است.

اگر بازدیدکننده بخواهد به تفریحگاه دیگری برود، دوباره به باجه می رود و بلیط یک روزه خود را نشان می دهد. سپس روند مراحل 5، 6، 7 دوباره تکرار می شود، فقط با نگهبان و تفریحگاه دیگری.



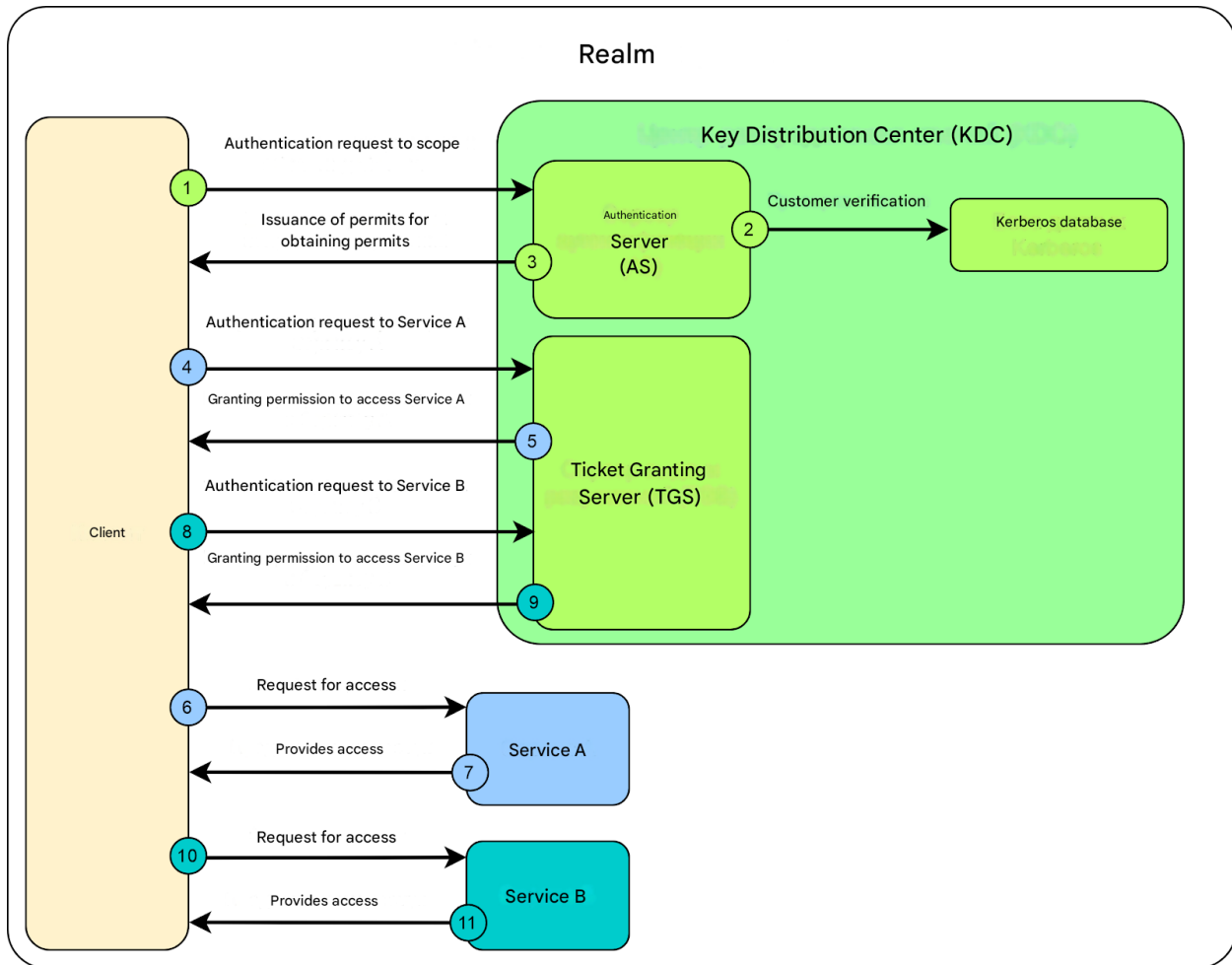
این مثال به ما کمک می‌کند تا مفهوم کنترل دسترسی و احراز هویت را بهتر درک کنیم. در اینجا، پایگاه داده مانند یک سیستم احراز هویت است که مشخص می‌کند چه کسانی اجازه ورود دارند. بلیط روزانه حکم یک توکن دسترسی است که به بازدیدکننده اجازه می‌دهد در طول روز به تفریحگاه‌ها دسترسی پیدا کند. هر بار که بازدیدکننده به یک تفریحگاه می‌رود، بلیط تفریحگاه مانند یک مجوز خاص برای آن بخش است که توسط مسئول تفریحگاه بررسی می‌شود.

در زمینه تست نفوذ و تیم قرمز، این مثال به ما نشان می‌دهد که چگونه می‌توانیم مراحل مختلف دسترسی به یک سیستم را شبیه‌سازی کنیم. مثلاً ابتدا باید هویت کاربر را تأیید کنیم (مانند بررسی کارت عبور)، سپس دسترسی کلی به سیستم را صادر کنیم (مانند بلیط روزانه)، و در نهایت دسترسی به بخش‌های خاص سیستم را کنترل کنیم (مانند بلیط تفریحگاه و بررسی توسط مسئول).

اگر بخواهیم این را در تیم قرمز به کار ببریم، می‌توانیم از این مدل برای شبیه‌سازی حملات چندمرحله‌ای استفاده کنیم که در آن ابتدا باید به سیستم وارد شویم، سپس دسترسی‌های مختلف را به تدریج به دست آوریم و در نهایت به اهداف خاص برسیم. این روش به ما کمک می‌کند تا نقاط ضعف در کنترل دسترسی و احراز هویت را بهتر شناسایی کنیم و حملات پیچیده‌تر را شبیه‌سازی کنیم.

مرور کلی فرآیند

حالا به صورت مشابه، یک طرح ساده‌شده از احراز هویت با استفاده از Kerberos را در نظر بگیریم:



طرح کلی مبادله درخواست‌ها در Kerberos

1. مشتری (Client) یک درخواست احراز هویت برای دامنه (Realm) ارسال می‌کند .
2. سرور احراز هویت (Authentication Server) ، اعتبار کلاینت را با استفاده از پایگاه داده Kerberos بررسی می‌کند .
3. سرور یک مجوز (تا اینجا آن را TGT می‌نامیم) به کلاینت صادر می‌کند تا بتواند به صورت جداگانه مجوزهای لازم (در ادامه به آنها ST می‌گوییم) برای دسترسی به سرویس‌های داخل دامنه را دریافت کند .
4. کلاینت با استفاده از مجوز دریافت شده در مرحله ۳ (TGT) ، درخواست مجوز دسترسی به سرویس A (ST برای A) را ارسال می‌کند .



5. سرور صدور مجوزها (Ticket Granting Server)، TGT را بررسی می‌کند و یک ST برای دسترسی به سرویس A به کلاینت می‌دهد.
 6. کلاینت با استفاده از « ST برای A » درخواست دسترسی به منابع سرویس A را می‌دهد.
 7. سرویس « A ST برای A » را بررسی می‌کند و در صورت معتبر بودن، دسترسی به منابع خود را به کلاینت می‌دهد. در صورت لزوم، سرویس نیز فرآیند احراز هویت خودش را نسبت به کلاینت انجام می‌دهد.
 - در صورت نیاز به دسترسی به یک سرویس دیگر:
 8. کلاینت با استفاده از مجوز دریافت شده در مرحله ۳ (TGT)، درخواست مجوز دسترسی به سرویس B (ST برای B) را ارسال می‌کند.
 9. سرور صدور مجوزها (TGS)، TGT را بررسی می‌کند و یک ST برای دسترسی به سرویس B به کلاینت می‌دهد.
 10. کلاینت با استفاده از « ST برای B » درخواست دسترسی به منابع سرویس B را می‌دهد.
 11. سرویس « B ST برای B » را بررسی می‌کند و در صورت معتبر بودن، دسترسی به منابع خود را به کلاینت می‌دهد.
- متوجه می‌شویم که طرفین با هم پیام‌هایی شامل درخواست‌ها و پاسخ‌های حاوی مجوزها را تبادل می‌کنند. قالب رسمی این پیام‌ها در مستند RFC 4120 سندی شده است.
- حالا بیایید پیام‌های ارسالی را مطابق با RFC تغییر نام دهیم:
- درخواست احراز هویت به دامنه (مرحله ۱): پیام KRB_AS_REQ.
- پاسخ سرور به درخواست احراز هویت کلاینت (مرحله ۳): پیام KRB_AS_REP.
- مجوز برای دریافت مجوزها: TGT (Ticket Granting Ticket).
- نام‌های دیگری که در منابع دیده می‌شود: مجوز / بلیط برای دریافت مجوزها، هویت اولیه کاربر.
- نکته: در منابع مختلف اغلب عبارت «TGT ticket» استفاده می‌شود، اما در خود اختصار TGT واژه "ticket" وجود دارد (Ticket Granting Ticket)، بنابراین بهتر است فقط «TGT» گفته شود.



- درخواست دسترسی به سرویس (مرحله ۴): پیام KRB_TGS_REQ .
 - پاسخ سرور صدور مجوزها (مرحله ۵): پیام KRB_TGS_REP .
 - مجوز دسترسی به سرویس : ST (Service Ticket) . نامهای دیگر TGS ticket ، service ticket ، service credential .
 - درخواست احراز هویت کلاینت به سرویس (مرحله ۶): پیام KRB_AP_REQ .
 - پاسخ اختیاری حاوی احراز هویت سرویس نسبت به کلاینت (مرحله ۷): پیام KRB_AP_REP .
- نحوه به خاطر سپردن نامهای پیامها :

KRB ~ KeRBeros
AS ~ Authentication Server
REP ~ REsPonse
REQ ~ REQuest
AP ~ APplication server

خلاصه تمام مراحل :

هر مرحله از تعاملات Kerberos شامل تبادل پیامهایی است که در قالب RFC 4120 استانداردسازی شدهاند. این پیامها شامل درخواستها و پاسخهایی هستند که به منظور احراز هویت اولیه، دریافت TGT، و در نهایت دریافت ST برای دسترسی به سرویسهای مختلف ارسال میشوند .

در ادامه هر درخواست با جزئیات بیشتری بررسی خواهد شد.

استفاده از Kerberos در تیم قرمز (Red Team) چگونه است؟

در تست نفوذ و عملیات تیم قرمز (Red Teaming)، Kerberos یکی از مهم‌ترین پروتکل‌هایی است که مورد توجه قرار می‌گیرد. زیرا در شبکه‌های ویندوزی (به خصوص محیط‌های Active Directory) نقش اصلی را در مدیریت احراز هویت ایفا می‌کند .

چند روش شناخته شده استفاده از Kerberos در تست نفوذ :

1. Pass-the-Ticket (PtT)

در این روش، مهاجم TGT یا ST معتبری را که از یک سیستم سرقت شده است، بدون داشتن رمز عبور به صورت مستقیم در سیستم دیگری استفاده می‌کند .



2. Golden Ticket

با دسترسی به کلید KRBTGT (که تنها در Domain Controller ذخیره می‌شود)، مهاجم می‌تواند یک TGT جعلی ایجاد کند که به او اجازه دسترسی به تمام منابع دامنه را می‌دهد. این TGT حتی می‌تواند تاریخ انقضای طولانی یا غیر محدود داشته باشد.

3. Silver Ticket

در این روش، مهاجم یک ST جعلی برای دسترسی به یک سرویس خاص (مانند SMB یا SQL) ایجاد می‌کند. برخلاف Golden Ticket، Silver Ticket نیازی به دسترسی به Domain Controller ندارد، اما فقط برای یک سرویس خاص قابل استفاده است.

4. Overpass-the-Hash / Pass-the-Key

در این روش، مهاجم با داشتن هش NTLM یا کلید تشفیر کاربر (در صورت عدم استفاده از رمز عبور ضعیف)، مراحل AS-REQ و AS-REP را دور می‌زند و مستقیماً TGT دریافت می‌کند.

5. Kerberoasting

این روش شامل درخواست ST برای سرویس‌های تحت حساب کاربری (مانند SPN) هایی که به حساب‌های کاربری اختصاص داده شده‌اند) است. سپس این ST را می‌توان به صورت آفلاین کرک کرد تا رمز عبور دارنده آن کشف شود.

6. Unconstrained Delegation & S4U Attacks

این روش‌ها شامل دستکاری در تنظیمات Unconstrained Delegation در Active Directory هستند. مهاجم می‌تواند با فعال‌سازی این تنظیمات، به صورت غیرمستقیم TGT یا ST کاربران دیگر را بدست آورد.

در محیط‌های Windows و Active Directory، Kerberos یک پروتکل امنیتی حیاتی است، اما در صورت نادیده گرفتن تنظیمات امنیتی صحیح، می‌تواند نقطه شروعی برای حملات جدی باشد. تیم‌های قرمز با شناسایی نقاط ضعف موجود در پی‌گیری Kerberos، قادر به دسترسی عمیق و مخفی به منابع شبکه خواهند بود.

تحلیل فرآیند احراز هویت در کربروس بر اساس RFC



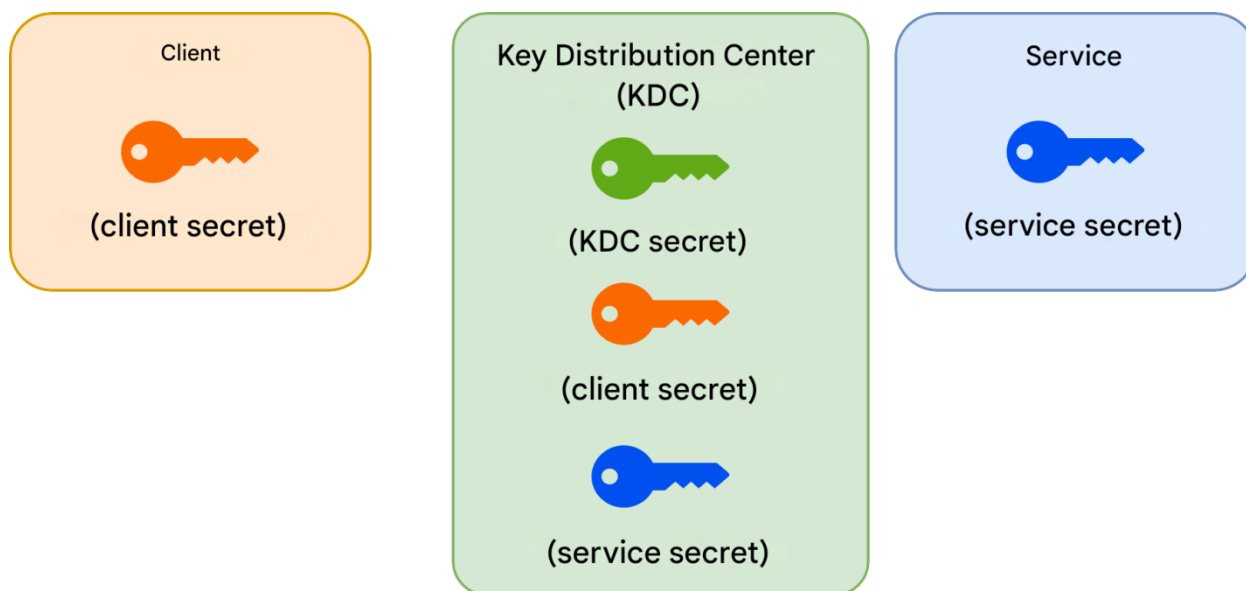
در ابتدا سه participants در پروتکل Kerberos وجود دارند:

کلائنت (Client)

سرویس (Service)

مرکز توزیع کلید (Key Distribution Center - KDC)

هر یک از participants دارای secret keys خود هستند. علاوه بر این، مرکز توزیع کلید دارای secret تمام participants می باشد.



شکل ۳ - توزیع اولیه کلیدهای مشترک (secrets)

الگوریتم تشکیل کلید

کلید به عنوان نتیجه عملکرد تابع هش با نام **string2key** تشکیل می شود. محاسبه هش می تواند به روش های مختلفی بسته به تنظیمات مربوطه در Kerberos انجام شود. به ویژه، الگوریتم های زیر پشتیبانی می شوند:



Algorithm name (etype)	Key calculation method
RC4_HMAC_MD5	NT hash of the participant's password
AES128_CTS_HMAC_SHA1_96	PBKDF2 (password, salt*, kvno**, 128)
AES256_CTS_HMAC_SHA1_96	PBKDF2 (password, salt*, kvno**, 256)

در نسخه‌های اخیر ویندوز، رمزنگاری **AES** به طور پیش فرض استفاده می‌شود. اما برای حفظ سازگاری با سیستم‌های قدیمی‌تر از ویندوز ویستا و ویندوز سرور 2008، پشتیبانی از الگوریتم **RC4** ضروری باقی می‌ماند.

نحوه تشکیل Salt :

- برای کاربران دامنه:

نام کامل دامنه به حروف بزرگ + (FQDN) نام کاربری با حساسیت به حروف بزرگ و کوچک

مثال DOMAIN.LOCALuser :

- برای کامپیوترها:

+ FQDN کلمه + host نام کامپیوتر با حساسیت به حروف بزرگ و کوچک (بدون علامت \$ در انتها)

مثال :

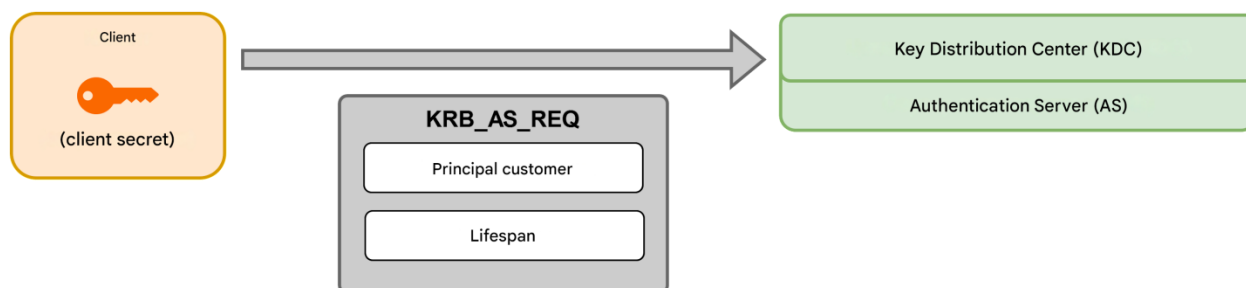
DOMAIN.LOCALhostcomputer.domain.local

kvno (شماره نسخه کلید):

- یک شمارنده است که با هر بار تغییر رمز عبور افزایش می‌یابد
- تضمین می‌کند حتی با وجود یکسان بودن رمز عبور در دامنه‌های مختلف، هش‌های متفاوتی تولید شود
- ساخت جداول رنگین‌کمانی (Rainbow Tables) برای این هش‌ها بی‌فایده است



KRB_AS_REQ



کلاینت یک درخواست را به سرور احراز هویت ارسال می کند که شامل موارد زیر است:

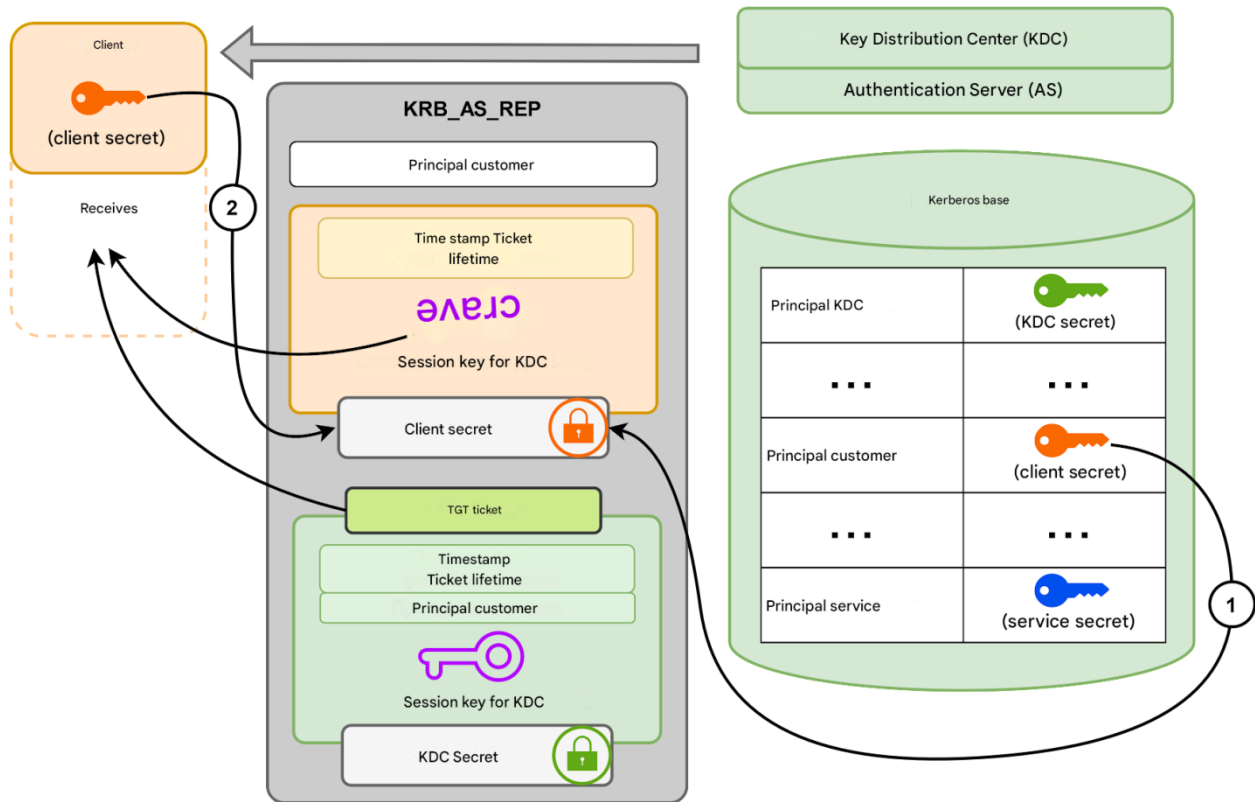
هویت کلاینت (Client Principal)

مدت اعتبار بلیط (Ticket Lifetime)

نکته: اگر این اولین مطلبی نیست که درباره Kerberos می خوانید و سوال می پرسید که چرا احراز هویت پیشین (Pre-authentication) وجود ندارد، باید بگوییم: این یک تنظیم اختیاری از پروتکل است که در پیاده سازی "کلاسیک" Kerberos به صورت پیش فرض غیرفعال است. اما در پیاده سازی Kerberos برای Active Directory، این تنظیم دقیقاً برعکس است و به طور پیش فرض فعال است و در ادامه به آن خواهیم پرداخت.



KRB_AS_REP



سرور احراز هویت با استفاده از هویت (Principal) کلاینت که دریافت کرده است، راز مربوط به آن کاربر را در پایگاه داده Kerberos پیدا می‌کند. همچنین برای ادامه‌ی ارتباط با KDC، سرور یک کلید جلسه (Session Key) به صورت تصادفی تولید می‌کند. در نهایت، دو پیام به کلاینت ارسال می‌شود.

پیام اول با استفاده از کلاینت سکرت رمزگذاری شده و شامل موارد زیر است :

- کلید جلسه برای ارتباط با KDC
- برچسب زمانی (Timestamp)
- مدت اعتبار TGT

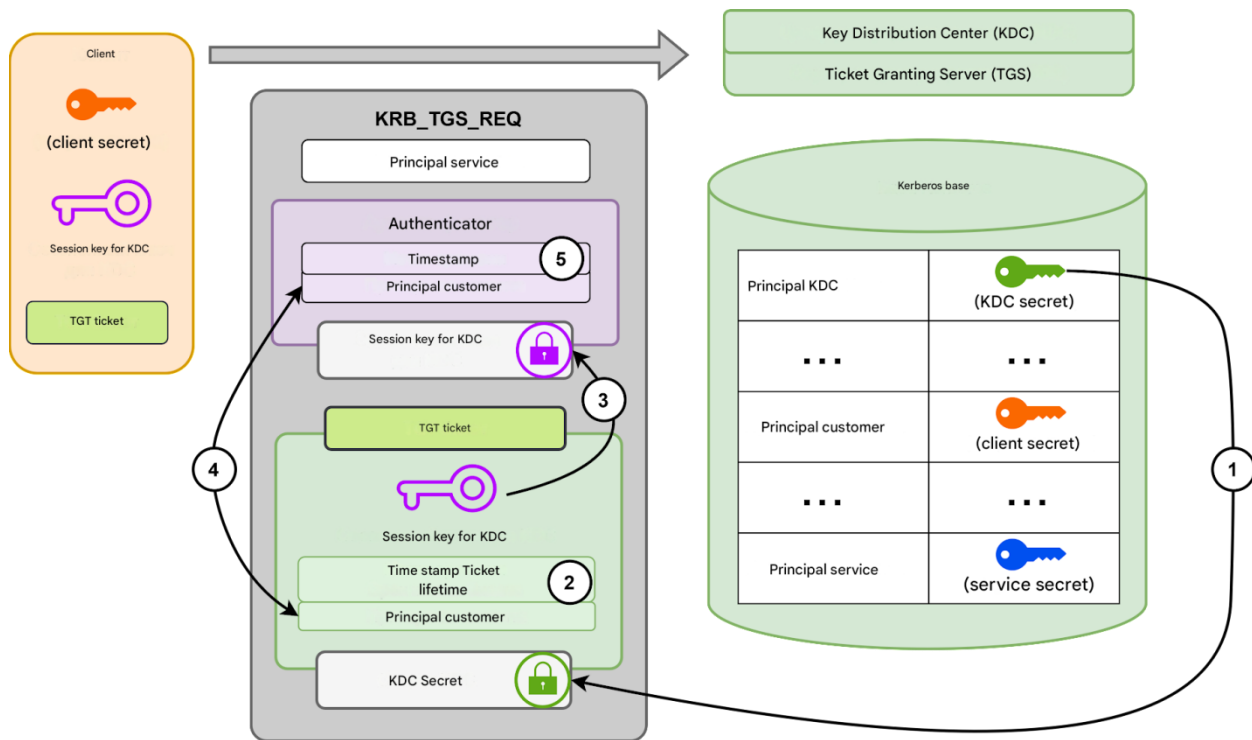


پیام دوم (که همان TGT است)، با استفاده از سکرِت خود KDC رمزگذاری می‌شود و شامل همان اطلاعات پیام اول است، اما علاوه بر آن، هویت کلاینت (Client Principal) نیز در آن وجود دارد.

نکته: مدت اعتبار TGT برابر با کمترین مقدار بین مدت درخواستی از سوی کلاینت و مقدار تنظیم‌شده در مرکز توزیع کلیدها (KDC) تعیین می‌شود.

کلاینت وقتی این پاسخ را دریافت می‌کند، تنها قادر به رمزگشایی پیام اول است. به این ترتیب، کلید جلسه لازم برای ادامه ارتباط با KDC را به دست می‌آورد TGT. نیز در کلاینت ذخیره می‌شود، اما به صورت رمزگذاری شده و بدون امکان دسترسی مستقیم تا زمان استفاده بعدی.

KRB_TGS_REQ



اکنون که کلاینت مراحل احراز هویت را با موفقیت پشت سر گذاشته است، قصد دارد به یک سرویس خاص دسترسی پیدا کند. برای این منظور، او یک درخواست به سرور صدور مجوزها (TGS) ارسال می‌کند که شامل موارد زیر است:



- هویت (Principal) سرویس مورد نظر
- یک احرازکننده (Authenticator) ، که از هویت کلاینت و برچسب زمانی تشکیل شده و با استفاده از کلید جلسه‌ای که قبلاً استخراج کرده بود، رمزگذاری شده است .
- TGT ذخیره شده

پس از دریافت این درخواست، سرور صدور مجوزها ابتدا داده‌های دریافتی را بررسی می‌کند. اول از همه، با استفاده از سکرت KDC، TGT را رمزگشایی می‌کند (۱) و سپس با بررسی برچسب زمانی و مدت اعتبار آن، مطمئن می‌شود که TGT هنوز معتبر است و منقضی نشده است (۲).

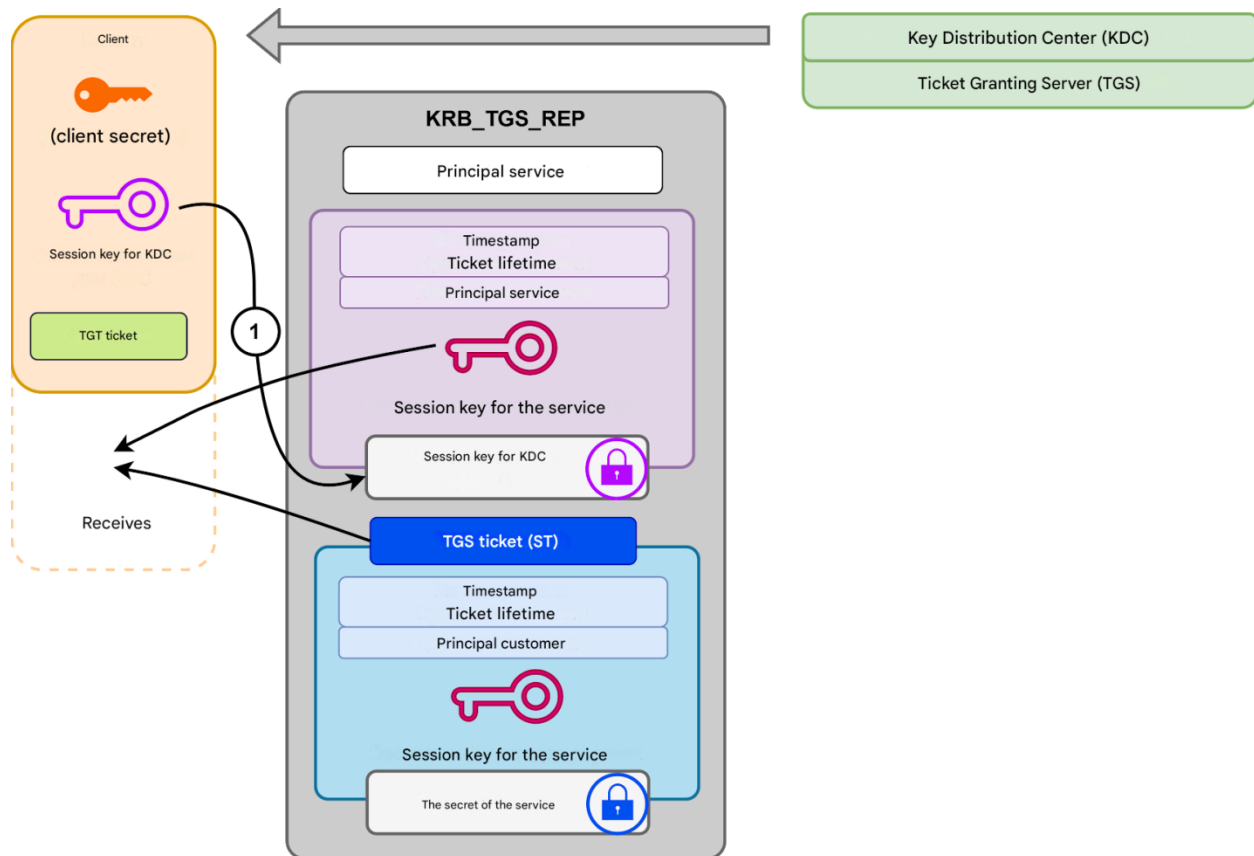
سپس سرور کلید جلسه برای KDC را استخراج می‌کند. با وجود اینکه این کلید در KDC ایجاد شده است، نیازی به ذخیره آن در پایگاه داده Kerberos نیست. در واقع، TGT نمی‌تواند توسط کسی غیر از KDC تغییر یابد، بنابراین داده‌های استخراج‌شده از آن قابل اعتماد هستند.

سوالی مهم مطرح می‌شود - چرا می‌توان اطمینان داشت که TGT توسط مهاجمی که آن را در حین شنود ترافیک شبکه سرقت کرده، ارسال نشده است؟ برای این منظور، در درخواست یک شناسنامه (authenticator) ضمیمه می‌شود. Authenticator با استفاده از کلید جلسه KDC که فقط توسط کلاینت خاصی از درخواست KRB_AS_REP استخراج شده، رمزگذاری می‌شود. برچسب زمانی به منظور جلوگیری از حملات بازپخش (replay attacks) اضافه می‌شود تا حمله‌کننده نتواند Authenticator قدیمی کلاینت که از پیام‌های گذشته سرقت کرده است را در درخواست خود وارد کند.

سرور صدور مجوزها، User Principals را از TGT و Authenticator مقایسه می‌کند و همچنین اطمینان حاصل می‌کند که Authenticator حداکثر دو دقیقه پیش ساخته شده باشد.



KRB_TGS_REP



در صورت موفقیت آمیز بودن بررسی‌ها، سرور صدور مجوزها پاسخ خود را به کلاینت ارسال می‌کند که شامل دو پیام است. پیام اول با استفاده از کلید جلسه برای KDC رمزگذاری شده و شامل موارد زیر است:

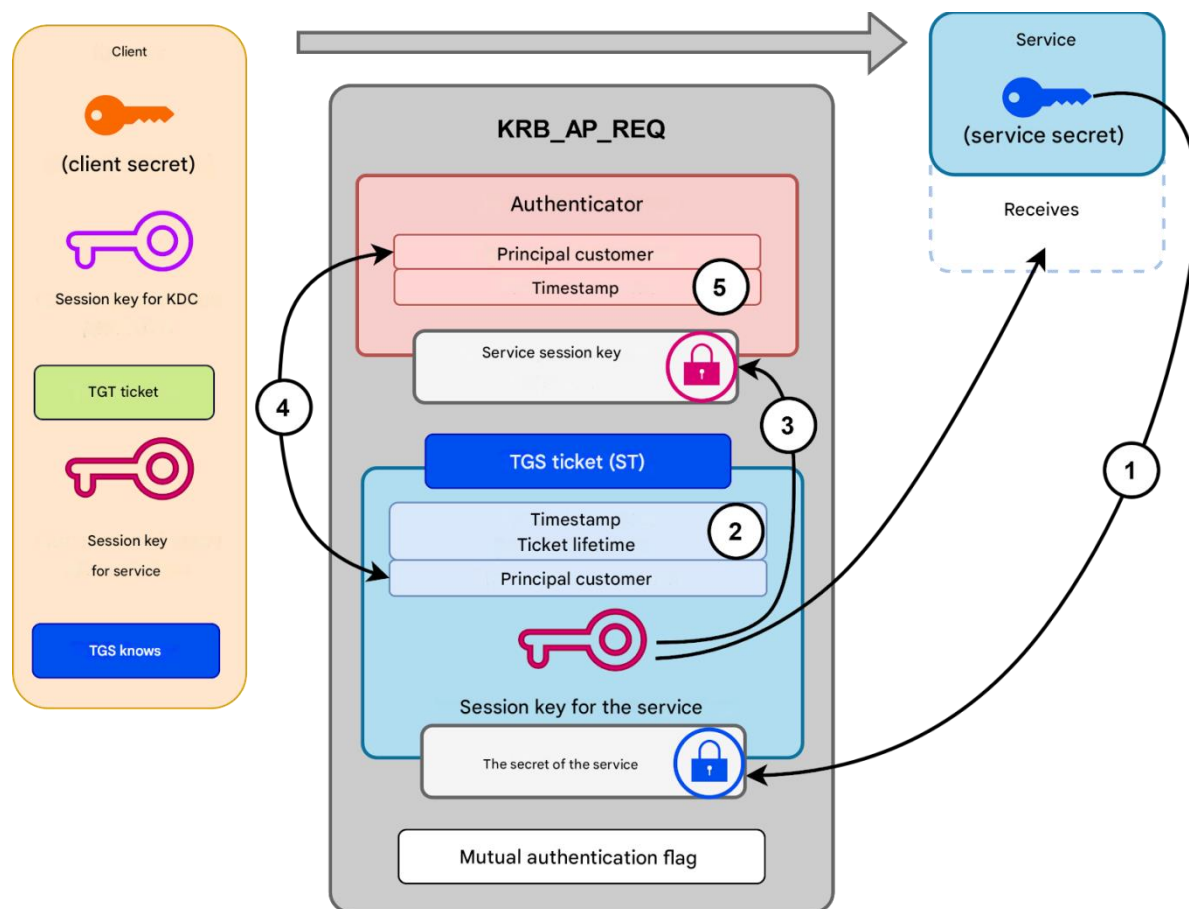
- کلید جلسه برای ارتباط با سرویس
- برچسب زمانی
- مدت زمان اعتبار بلیط TGS
- اصل سرویس

پیام دوم (بلیط TGS) با استفاده از رمز سرویس رمزگذاری شده و شامل همان داده‌هایی است که در پیام اول وجود دارد، همچنین Principals کلاینت نیز در آن گنجانده شده است. کلاینت پس از دریافت پاسخ، فقط می‌تواند پیام اول را



رمزگشایی کند. به این ترتیب، او کلید جلسه برای ارتباط بعدی با سرویس را دریافت می‌کند. بلیط TGS به صورت رمزگذاری شده نزد کلاینت باقی می‌ماند.

KRB_AP_REQ



کلاینت درخواستی برای دریافت دسترسی به سرویس ارسال می‌کند که شامل موارد زیر است:

- Authenticator که از Principals کلاینت و برچسب زمانی تشکیل شده و با استفاده از کلید جلسه‌ای که قبلاً برای ارتباط با سرویس استخراج شده، رمزگذاری شده است.
- بلیط TGS ذخیره شده



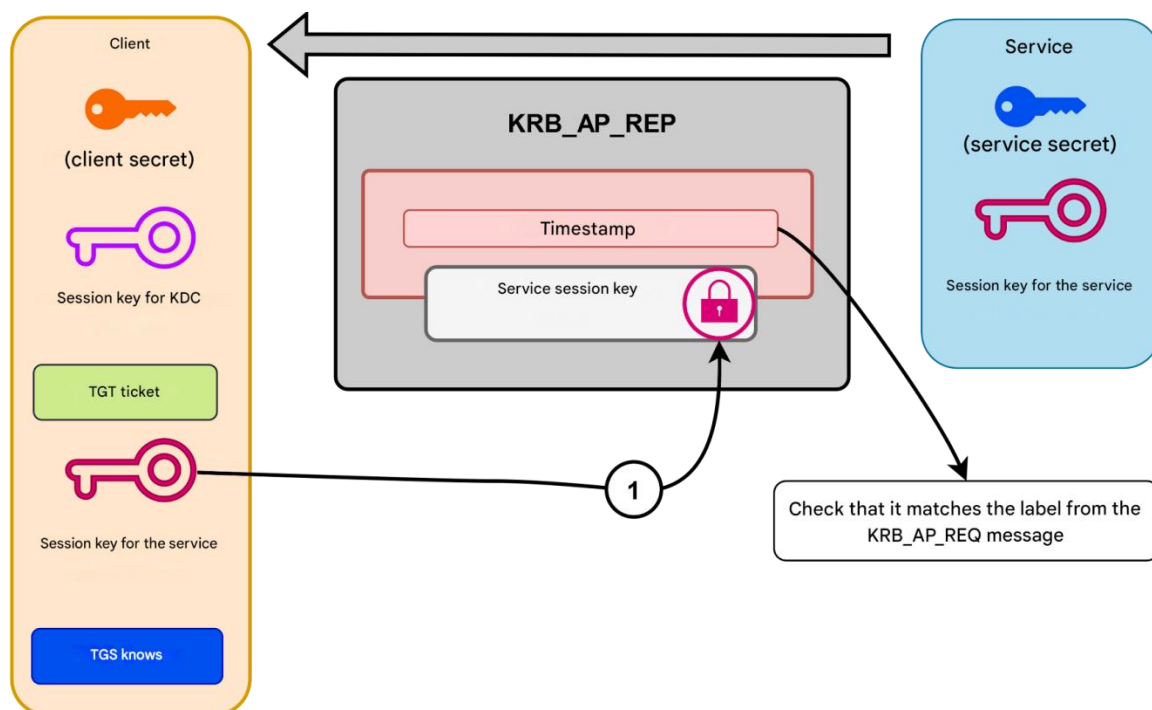
- پرچم احراز هویت متقابل (Mutual Authentication Flag)

پس از دریافت درخواست، سرویس ابتدا داده‌های دریافتی را بررسی می‌کند. ابتدا با استفاده از رمز خود، سرویس بلیط TGS را رمزگشایی می‌کند (1) و با بررسی برچسب زمانی و مدت زمان اعتبار آن اطمینان حاصل می‌کند که بلیط TGS منقضی نشده است (2). سپس سرویس کلید جلسه را استخراج می‌کند.

بلیط TGS نمی‌تواند توسط کسی غیر از کسی که رمز سرویس را می‌داند تغییر کند، که شامل KDC و خود سرویس می‌شود. سرویس به KDC اعتماد دارد، بنابراین داده‌های استخراج‌شده از بلیط TGS نیز برای سرویس قابل اعتماد است.

به طور مشابه، در درخواست KRB_TGS_REQ، Authenticator رمزگشایی شده و بررسی‌های دیگر انجام می‌شود. توجه داشته باشید که سرویس صحت کلاینت را تأیید می‌کند بدون اینکه به KDC مراجعه کند.

KRB_AP_REP



اختیاری، در صورتی که پرچم احراز هویت متقابل فعال باشد، سرویس همچنین صحت خود را در برابر کلاینت تأیید می‌کند و پاسخی حاوی برچسب زمانی ارسال می‌کند که با استفاده از کلید جلسه رمزگذاری شده است.



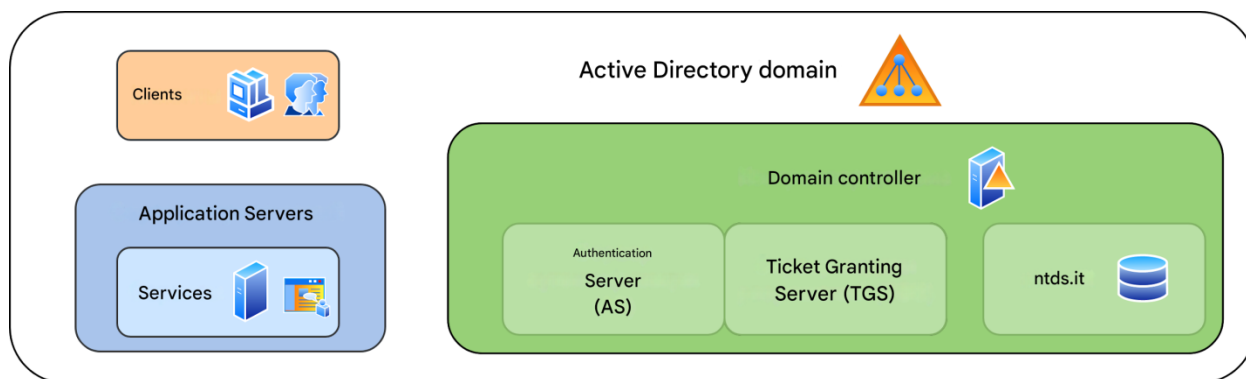
کربروس در اکتیو دایرکتوری

برای رساندن یک ایده، باید آن را سه بار بیان کرد، اما با واژه‌های متفاوت (نقل قول)

اجرای Kerberos در اکتیو دایرکتوری را بررسی می‌کنیم. ابتدا اصطلاحات را دقیق‌تر تعریف می‌کنیم:

- حوزه عمل (Realm) : دامنه (Domain) .
- مرکز توزیع کلید (KDC) : کنترلر دامنه (Domain Controller) .
- سرور احراز هویت (AS) و سرور صدور مجوز (TGS) : هر دو در قالب یک کامپوننت واحد روی کنترلر دامنه پیاده سازی شده‌اند.
- پایگاه داده Kerberos : در اکتیو دایرکتوری، اطلاعات مربوط به سکرت های کاربران در فایل ntds.dit روی کنترلرهای دامنه ذخیره می‌شود.
- Krbtgt : نام حساب کاربری پیش فرضی است که همراه با ایجاد دامنه ساخته می‌شود و راز (Secret) کنترلر دامنه را در اختیار دارد.

با اعمال این تغییرات terminological، ساختار نهایی به شکل زیر خواهد بود:



به طور کلی، Kerberos در اکتیو دایرکتوری مطابق با استانداردهای RFC عمل می‌کند، اما دارای یک سری ویژگی‌های خاص است. اجازه دهید این ویژگی‌های منحصر به فرد را با مثال زیر بررسی کنیم.

کاربرد در تیم قرمز (Red Team) :

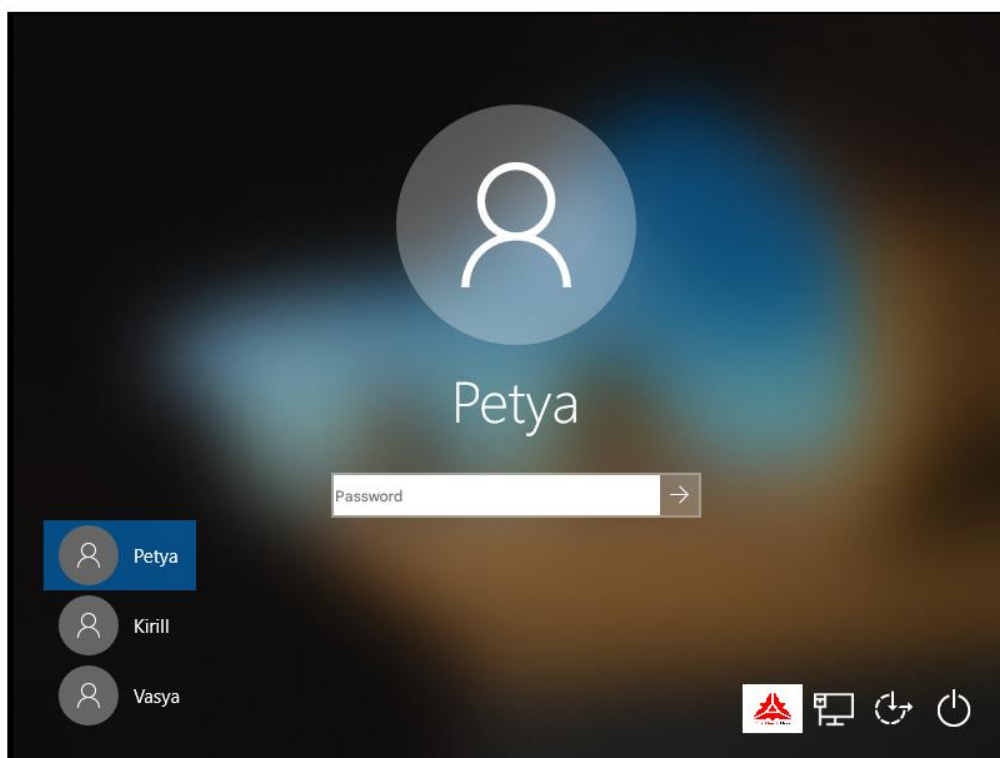
در عملیات تست نفوذ، آگاهی از این ویژگی‌های خاص Kerberos در اکتیو دایرکتوری می‌تواند به مهاجمان کمک کند تا:



- 1 - حملات Golden Ticket را با سوءاستفاده از حساب krbtgt اجرا کنند
 - 2 - از تکنیک‌های Pass-the-Ticket برای حرکت جانبی در شبکه استفاده نمایند
 - 3 - با استفاده از ابزارهایی مانند Mimikatz ، تیکت‌های Kerberos را استخراج و دستکاری کنند
 - 4 - از تفاوت‌های پیاده‌سازی میکروسافت برای دور زدن مکانیزم‌های امنیتی استفاده کنند
- این ویژگی‌های خاص اغلب در حملات پیشرفته تیم‌های قرمز مورد بهره‌برداری قرار می‌گیرند.

احراز هویت کاربر دامنه در ایستگاه کاری در اکتیو دایرکتوری

در ابتدا پنجره محاوره‌ای زیر به صورت فعال در ایستگاه کاری نمایش داده می‌شود:



کاربر اطلاعات ورود خود را وارد می کند (نام دامنه، نام حساب کاربری، رمز عبور) و روی «OK» کلیک می کند. سپس کامپوننتی که مسئول نمایش پنجره دیالوگ است، درخواست احراز هویت کاربر را با استفاده از داده های وارد شده به مرکز امنیت محلی (LSA، Local Security Authority) ارسال می کند. این مرکز شامل کتابخانه های داینامیکی مختلفی است که عملکردهایی برای پروسس های احراز هویت، تغییر رمز عبور و همچنین صدور توکن ها ارائه می دهند. این کتابخانه ها فراخوانی شده و در زمینه پروسس lsass.exe (Local Security Authority Subsystem Service) اجرا می شوند.



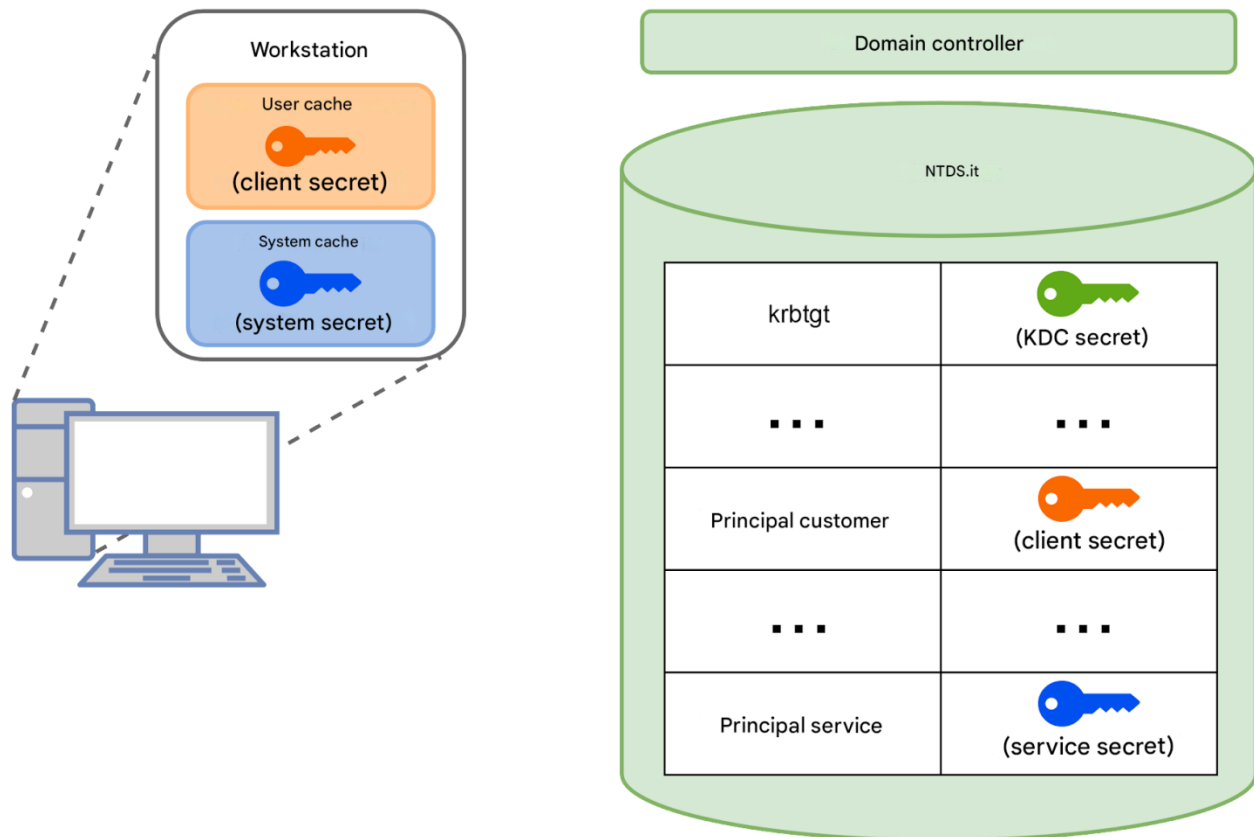
بسته به نوع درخواست، کتابخانه مناسب برای پردازش آن انتخاب می‌شود. نمونه‌هایی از کتابخانه‌ها و پروتکل‌ها عبارتند از:

کتابخانه	پروتکل مرتبط	کاربرد
msv1_0.dll	NTLM	احراز هویت قدیمی ویندوز
kerberos.dll	Kerberos	احراز هویت مدرن دامنه‌ای
SChannel.dll	TLS/SSL	ارتباطات امن شبکه‌ای
WDigest.dll	Digest Authentication	احراز هویت وب

به طور پیش‌فرض، برای پردازش درخواست‌های احراز هویت کاربر هنگام ورود به دامنه، کتابخانه kerberos.dll که پروتکل هم‌نام را پیاده‌سازی می‌کند، انتخاب می‌شود.

باید در نظر داشت که کاربر هرگز مستقیماً با سیستم تعامل ندارد. سیستم نماینده کاربر است و با استفاده از حقوق دسترسی که کاربر دارد، به منابع مورد نیاز دسترسی پیدا می‌کند. بنابراین، سیستم در طول فرآیند احراز هویت می‌تواند به عنوان یک سرویس در نظر گرفته شود.

در نهایت، تصویر کلی به صورت زیر است:

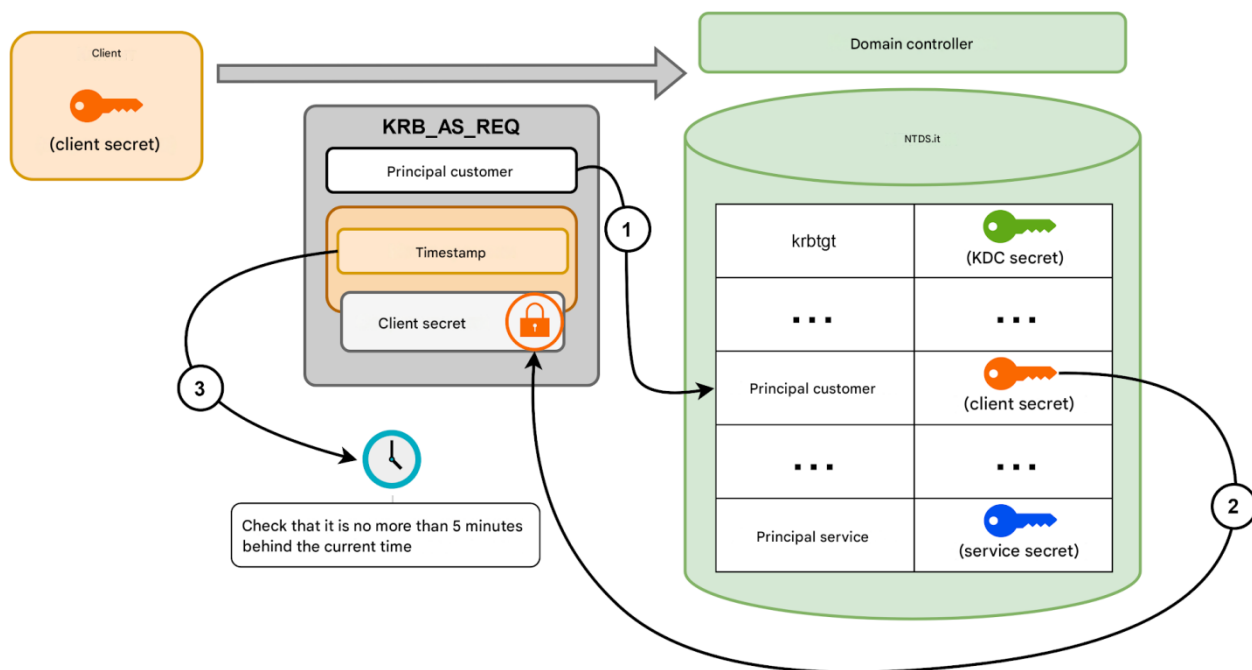


یک سکرِت سیستم (کلید) هنگام اضافه شدن ایستگاه کاری به دامنه به آن اختصاص داده می‌شود. لازم به ذکر است که رمز عبور وارد شده توسط کاربر در حافظه ایستگاه کاری ذخیره نمی‌شود. کلید کاربر با استفاده از تابع هش `string2key` که قبلاً بررسی شد تشکیل می‌شود.

سپس فرآیندی که احراز هویت کاربر را تضمین می‌کند، با استفاده از کلید تشکیل شده به کنترلر دامنه مراجعه می‌کند. در اینجا یکی از ویژگی‌های پیاده‌سازی Kerberos در Active Directory آشکار می‌شود - احراز هویت پیش‌فرض به طور پیش‌فرض فعال است.



درخواست KRB_AS_REQ با احراز هویت مقدماتی



در این حالت، کلاینت یک درخواست به سرور احراز هویت ارسال می‌کند که شامل موارد زیر است:

- شناسه کلاینت (Principal)
- یک برچسب زمانی که با استفاده از کلید مخفی کلاینت رمزنگاری شده است

پس از دریافت درخواست، کنترل‌کننده دامنه با استفاده از کلید مخفی کلاینت، برچسب زمانی را رمزگشایی کرده و آن را با زمان فعلی مقایسه می‌کند. اگر اختلاف زمان ارسال شده با زمان فعلی کمتر از پنج دقیقه باشد، به این معنی است که احراز هویت مقدماتی کلاینت با موفقیت انجام شده است. در غیر این صورت، کنترل‌کننده پیام خطا ارسال می‌کند.

این فرایند در تیم قرمز چگونه کاربرد دارد؟

در تیم قرمز، این فرایند احراز هویت Kerberos با احراز هویت مقدماتی اهمیت زیادی دارد چون معمولاً هدف تیم قرمز نفوذ به شبکه‌های سازمانی مبتنی بر Active Directory است. وقتی تیم قرمز می‌خواهد به منابع دامنه دسترسی پیدا کند یا هویت یک کاربر را جعل کند، باید بتواند این مرحله احراز هویت را عبور کند.



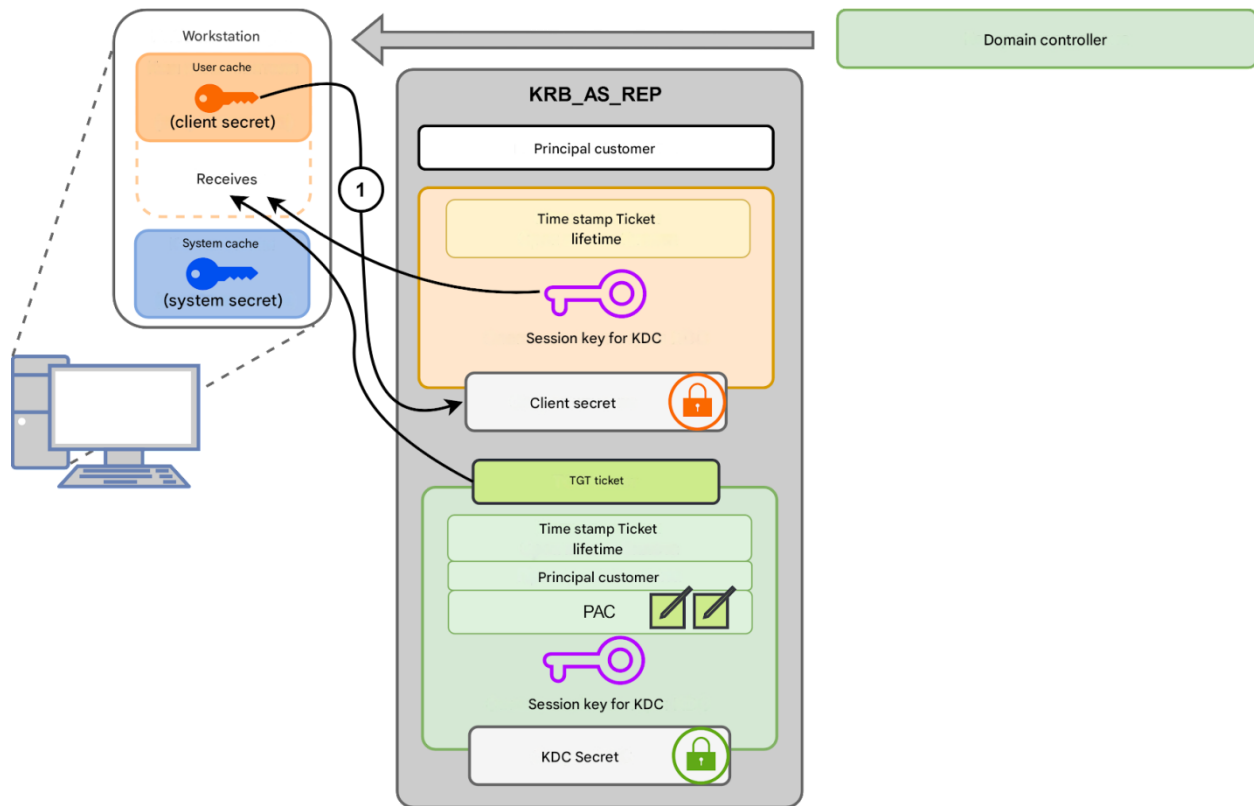
با درک نحوه کار KRB_AS_REQ و KRB_AS_REP، تیم قرمز می‌تواند حملاتی مثل Kerberoasting یا Pass-the-Ticket را اجرا کند که به استخراج توکن‌ها یا بلیط‌های Kerberos منجر می‌شود. این توکن‌ها سپس برای دسترسی به منابع مختلف در شبکه استفاده می‌شوند.

همچنین، تیم قرمز می‌تواند با شبیه‌سازی یا دستکاری این پیام‌ها، احراز هویت را دور بزند یا از آسیب‌پذیری‌های موجود در پیاده‌سازی Kerberos بهره‌برداری کند تا کنترل بیشتری روی شبکه به دست آورد.

به طور خلاصه، فهم دقیق این فرایند به تیم قرمز کمک می‌کند تا حملات پیشرفته‌تری انجام دهد و دسترسی‌های بیشتری در محیط هدف کسب کند.

KRB_AS_REP (Active Directory)

در صورت موفقیت در احراز هویت مقدماتی، کنترل‌کننده دامنه پاسخی به ایستگاه کاری ارسال می‌کند که مشابه پاسخی است که در بخش مربوط به RFC بررسی شد.



در پاسخ یک ویژگی جدید ظاهر شد، یعنی فیلد «PAC» در محتوای TGT .

PAC (Privilege Attribute Certificate) داده ایی است که برای مجوزدهی کاربر طراحی شده است. قبلاً ذکر شد که علاوه بر احراز هویت، Kerberos می تواند برای مجوزدهی نیز استفاده شود، اما نحوه آن توضیح داده نشد. فیلد PAC از ابتدا در RFC پیش بینی شده بود بدون توصیف مشخصی از محتوای آن. اینکه چه اطلاعاتی در PAC منتقل می شود و چگونه پردازش می شود به پیاده سازی خاص Kerberos بستگی دارد.

در Active Directory، PAC شامل اطلاعات زیر است:

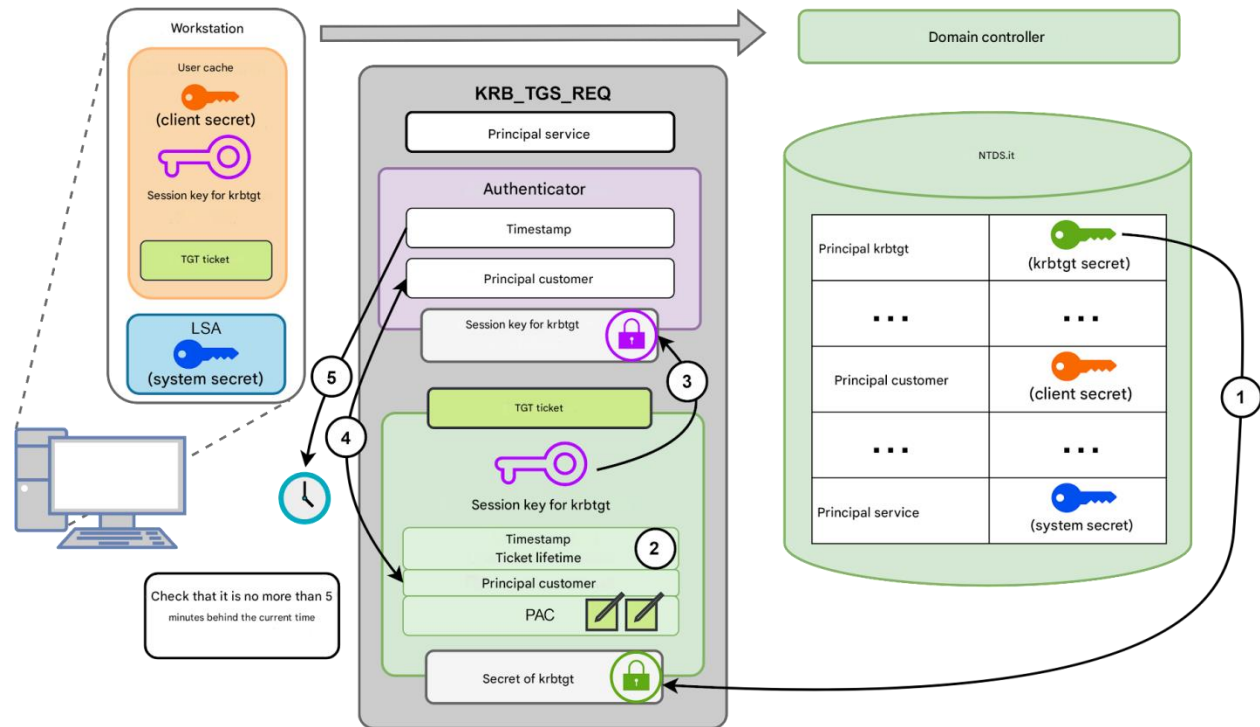
- شناسه امنیتی (SID) حساب کاربری کاربر
- شناسه های گروه هایی که کاربر در آن ها عضو است

این اطلاعات دو بار امضا می شوند. یک امضا متعلق به krbtgt است و دومی متعلق به سرویسی است که کلاینت به آن مراجعه کرده است (در مورد KRB_AS_REP نیز krbtgt است).



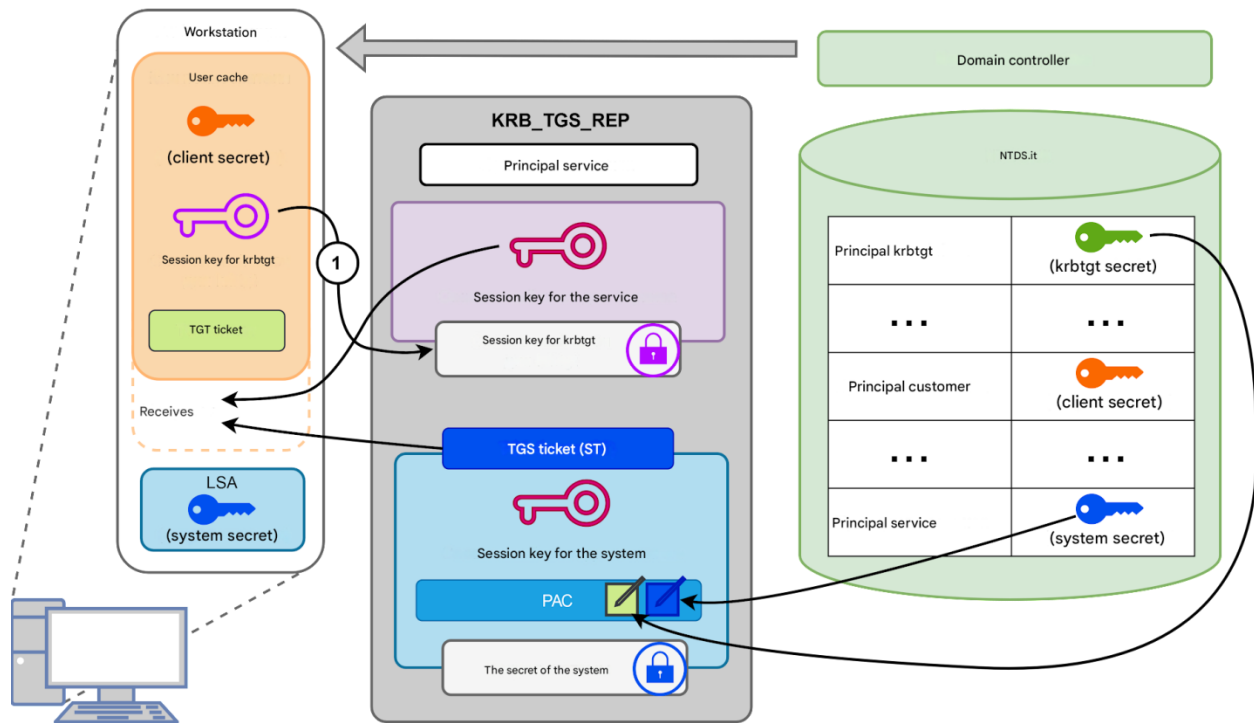
KRB_TGS_REQ (AD)

این درخواست به همان روشی که قبلاً در RFC بحث شد، انجام می‌شود.



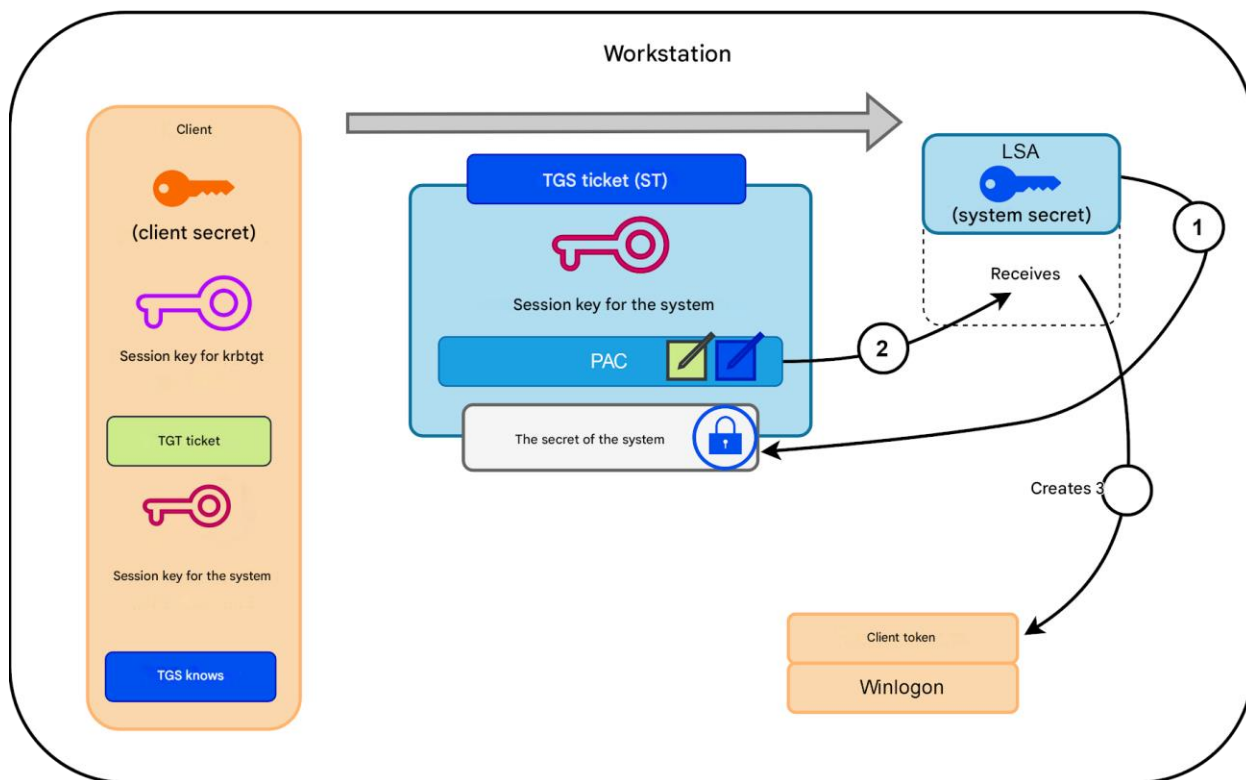
KRB_TGS_REP (AD)

PAC مربوط به TGT که در پیام قبلی دریافت شده بود، در بلیط TGS قرار می‌گیرد. این بار PAC نه تنها با استفاده از کلید مخفی krbtgt، بلکه با کلید مخفی سیستم نیز امضا می‌شود.



LOGON

با استفاده از کلید جلسه (session key)، LSA، PAC امضا شده را از بلیط TGS استخراج می‌کند LSA. صحت امضای PAC را با استفاده از کلید مخفی سیستم بررسی می‌کند و سپس با در نظر گرفتن گروه‌های امنیتی دامنه که از PAC استخراج شده‌اند، فرآیند Winlogon را با توکن دسترسی متناظر برای کلاینت ایجاد می‌کند.



به صورت اختیاری، سیستم می‌تواند از کنترلر دامنه درخواست کند که بررسی اضافی امضای PAC را با استفاده از کلید مخفی krbtgt انجام دهد.

نتیجه‌گیری

به نظر من برای آشنایی مقدماتی با Kerberos کافی است. اگرچه بسیاری از نکات خارج از این بحث باقی ماندند، اما مطالب ارائه شده به طور کلی برای درک حملات علیه پروتکل Kerberos که در بخش‌های بعدی بررسی خواهیم کرد، کافی هستند.



دیگر آثار من :

راهنمای جامع ابزار Mimikatz : راهنمای هکرها

راهنمای جامع ابزار Mimikatz : راهنمای هکرها (نسخه دوم)

کربروس برای تست نفوذ و رد تیم